Lab 5 - Static Code Analysis

Name: Samyak Sanklecha
SRN: PES2UG24CS436

My repo was L5_02_retail_pos, a small shop billing script (pos_system.py). Ran it through pylint, bandit and flake8, fixed stuff, ran them again.

GitHub: https://github.com/samyak-1021/SE_Lab_PES2UG24CS436/tree/main/Lab5

Before

First just ran it. It works but the numbers are clearly off, bill 3 is -630 and bill 4 is 0.

```
Bill 1: 126.0
Bill 2: 838.95
Bill 3: -630.0
Bill 4: 0
After promo: 301.45500000000004
Enter promo code (e.g. total - 50):
After your promo: 284.95000000000005
Sales so far: 334.95000000000005
(.venv) (base) samyaksanklecha@Samyaks-MacBook-Air L5_02_retail_pos %
```

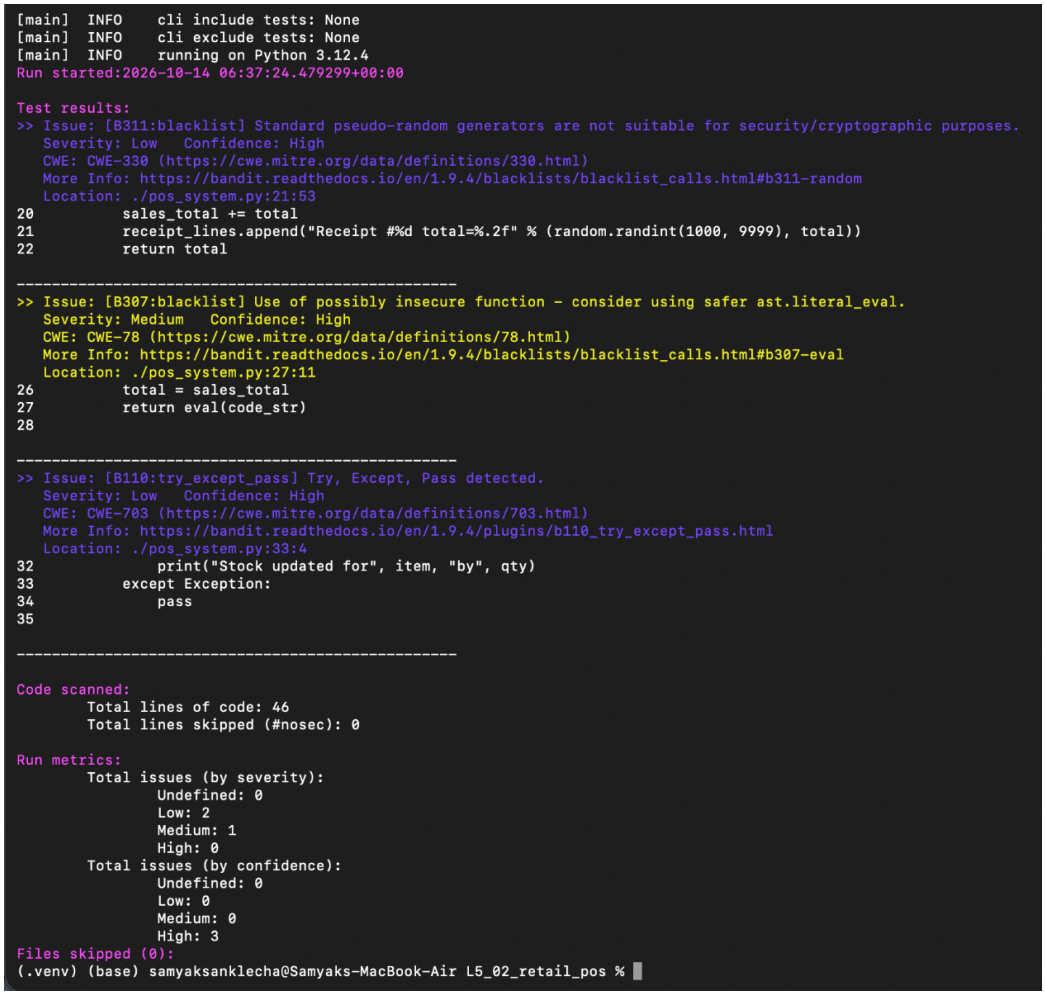
Pylint gave 5.65/10. missing docstrings, eval, global, bare except, mutable default arg etc.

```
************* Module pos_system
pos_system.py:1:0: C0114: Missing module docstring (missing-module-docstring)
pos_system.py:7:0: C0103: Constant name "sales_total" doesn't conform to UPPER_CASE naming style (invalid-name)
pos_system.py:10:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:10:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
pos_system.py:11:4: W0603: Using the global statement (global-statement)
pos_system.py:16:8: W0702: No exception type(s) specified (bare-except)
pos_system.py:21:25: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
pos_system.py:24:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:27:11: W0123: Use of eval (eval-used)
pos_system.py:26:4: W0612: Unused variable 'total' (unused-variable)
pos_system.py:29:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:33:11: W0718: Catching too general exception Exception (broad-exception-caught)
pos_system.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:37:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
pos_system.py:37:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
pos_system.py:41:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:41:0: C0103: Function name "printSales" doesn't conform to snake_case naming style (invalid-name)
pos_system.py:44:0: C0116: Missing function or method docstring (missing-function-docstring)
pos_system.py:1:0: W0611: Unused import json (unused-import)
pos_system.py:3:0: W0611: Unused import logging (unused-import)

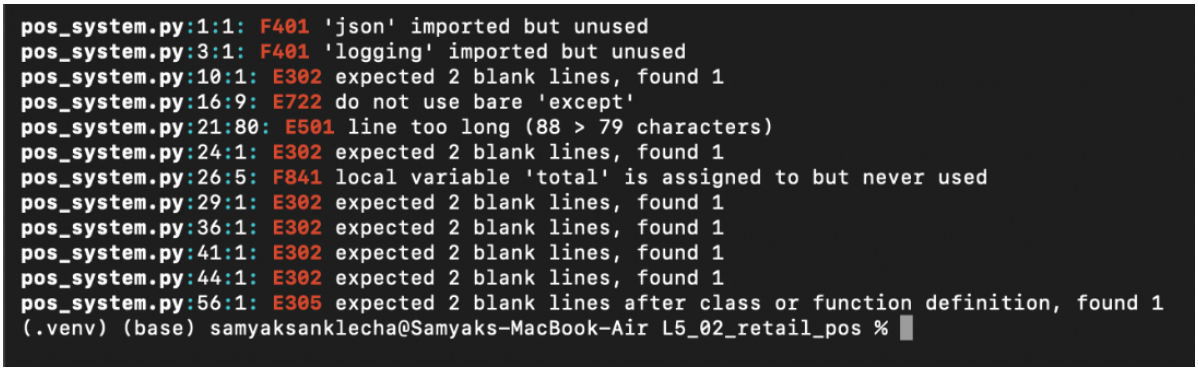
-----------------------------------
Your code has been rated at 5.65/10

(.venv) (base) samyaksanklecha@Samyaks-MacBook-Air L5_02_retail_pos %
```

Bandit found 3. the main one is eval() on the promo code input, so whatever you type runs as python code.



Flake8 had 12, mostly blank lines and unused imports.



What I fixed

- removed eval, promo code is now parsed and only 'total * x' or 'total - x' is allowed
- bare except was hiding errors and billing 0, now bad items/qty/tax just get rejected
- negative qty and negative tax are not allowed anymore
- receipts=[] default changed to None, global state moved into a small class
- file opened with 'with' + encoding, random receipt no. replaced with a counter
- docstrings, snake_case, f-strings and pep8 spacing

Did it in separate commits, one each for bandit, flake8 and pylint, and one for the logic bugs.

After

Wrong bills get rejected now with a reason instead of giving weird totals.

```
Bill 1: 126.0
Bill 2 rejected: Unknown item: laptop
Bill 3 rejected: Invalid quantity for bottle: -4
Bill 4 rejected: Invalid tax rate: -1
Stock not updated: Unknown item: laptop
After promo: 113.4
Enter promo code (e.g. total - 50):
After your promo: 76.0
Sales so far: 126.00
(.venv) (base) samyaksanklecha@Samyaks-MacBook-Air Lab5 %
```

Pylint 10.00/10

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 5.65/10, +4.35)

(.venv) (base) samyaksanklecha@Samyaks-MacBook-Air Lab5 %
```

Bandit, no issues

```
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.4
Run started:2026-10-14 06:38:32.601922+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 92
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
(.venv) (base) samyaksanklecha@Samyaks-MacBook-Air Lab5 %
```

Flake8, nothing

```
flake8: no issues found
(.venv) (base) samyaksanklecha@Samyaks-MacBook-Air Lab5 %
```

Commits

```
3b76c03 (HEAD -> main, origin/main, origin/HEAD) Lab5: add after reports, issues table and reflection
c27f4e0 Lab5: fix logic bugs not caught by the tools (input validation, money rounding, stock update, duplicate log lines)
c8a4529 Lab5: fix Pylint issues (docstrings, global state, mutable default, with/encoding, naming) - 10.00/10
7f04f9d Lab5: fix Flake8 issues (blank lines, line length, unused imports, bare except)
aa065da Lab5: fix Bandit issues (B307 eval, B311 random, B110 try-except-pass)
ebe2285 Lab5: add original pos_system.py and baseline static analysis reports
6c6220d Add SE Lab 3 - component diagram and architecture justification
(.venv) (base) samyaksanklecha@Samyaks-MacBook-Air Lab5 %
```

What I learnt

The tools catch a lot, but the -630 bill didn't show up in any of them. I only saw it by actually running the code. Also never put user input into eval.